

Clarity Information Security Policy

Version: 1.2 Effective Date: May 30, 2026 Owner: Pedro Martins, Founder Application: Clarity, including Rex, the AI financial co-pilot

Current Security Posture Summary

Clarity is an early-stage, solo-founder personal finance application preparing for Plaid Production access. Its current security posture is practical and intentionally transparent: user-authorized account connections through Plaid, Supabase Auth, user-scoped database access controls, HTTPS/TLS, managed infrastructure protections, restricted handling of Plaid data and credentials, limited administrative access, and a founder-led incident response process. Clarity does not claim enterprise certifications, a dedicated security team, or mature corporate security operations. This policy documents the controls Clarity uses or expects to maintain for production operation, while identifying areas that will mature as the company grows.

1. Introduction

Company

Clarity is a mobile personal AI financial co-pilot developed and operated by Pedro Martins as a solo founder. The app helps users understand spending, budgets, goals, and financial context through Clarity and Rex, the AI assistant inside the product.

Clarity is not a bank, broker, lender, investment adviser, tax adviser, accountant, law firm, or credit counselor. Clarity does not move money, execute transactions, open accounts, apply for credit, file taxes, or make financial decisions on behalf of users.

Purpose

This Information Security Policy describes how Clarity protects user data, Plaid-connected financial data, application systems, credentials, and supporting infrastructure. It is intended to support Plaid Production review, guide current operations, and establish a clear security baseline for future maturity.

Scope

This policy applies to the Clarity mobile application, Rex assistant features, backend services, APIs, serverless functions, databases, storage, authentication, Plaid integrations, AI providers, support workflows, source code repositories, production credentials, environment variables, operational logs, and deployment systems.

At the time of this policy, Pedro Martins is the only regular operator with administrative responsibility for Clarity. If employees, contractors, or other personnel are added later, they must follow this policy or a successor policy before receiving access to production systems or user data.

2. Information Security Objectives

Clarity's security objectives are to:

- Protect user-authorized financial data from unauthorized access, disclosure, alteration, or loss.
- Collect and retain only the data reasonably needed to provide Clarity, support users, secure the service, and meet operational or compliance needs.
- Use Plaid for bank connection flows so Clarity does not collect or store bank usernames or passwords.
- Authenticate users before giving access to private app data.
- Scope user data so each user can access only their own Clarity records.
- Protect production credentials, Plaid tokens, service keys, and secrets as restricted information.
- Use HTTPS/TLS for app, backend, website, and provider communications.
- Use managed infrastructure controls, including Supabase Auth, Supabase Row Level Security where applicable, and provider-supported encryption at rest.
- Limit internal access to legitimate operational, support, security, compliance, and user-requested purposes.
- Respond responsibly to suspected security incidents, vulnerabilities, or data exposure.
- Improve the security program as Clarity's product, team, and risk profile mature.

Clarity is intentionally honest about its stage. It does not currently operate a dedicated 24/7 security operations center, maintain SOC 2 certification, or run an enterprise vendor-risk program. Those may become appropriate later. The current goal is a disciplined, accurate, and practical security baseline for a solo-founder product handling sensitive financial context.

3. Data Classification and Handling

Clarity classifies information by sensitivity so access, storage, transmission, and incident response can be handled consistently.

Public Information

Public information may be shared on Clarity's website, app listings, public policies, or user-facing materials. Examples include product descriptions, public support instructions, privacy disclosures, terms, security pages, and data deletion pages.

Public materials must be accurate and must not claim Plaid endorsement, bank-grade security, legal review, formal certifications, guaranteed outcomes, or controls that have not been implemented.

Internal Information

Internal information supports product development and operations but is not intended for public release. Examples include product plans, implementation notes, non-production documentation, and testing records that do not contain real user data. Internal information should be stored only in founder-controlled or approved systems.

Confidential Information

Confidential information includes user or business information that could create privacy, security, or business risk if disclosed. Examples include user profile information, email addresses, budgets, goals, categories, financial summaries, Rex conversation history, memory, prompts, generated responses, support records, operational logs tied to user activity, vendor records, and non-public business records.

Confidential information may be accessed only for legitimate product, support, security, compliance, debugging, or user-requested purposes.

Restricted Information

Restricted information is the most sensitive category and requires the strongest practical protections available to Clarity. Examples include Plaid access tokens, item identifiers, account identifiers, connection metadata, user-authorized financial account and transaction data received through Plaid, authentication records, privileged database access, Supabase service-role keys, API keys, production database credentials, security incident records, and unresolved vulnerability details.

Restricted information must not be placed in public repositories, public issue trackers, screenshots, unsecured notes, chat messages, user support forms, or unapproved documents. Secrets must be stored in environment variables, deployment secret stores, Supabase configuration, or other appropriate secret-management mechanisms.

Plaid Financial Data Handling

Clarity uses Plaid to help users connect financial accounts with permission. Users authenticate with their financial institution through the Plaid-supported connection flow. Clarity does not ask users to send bank usernames or passwords to Clarity and does not store bank login credentials.

Depending on the user's institution, permissions, product configuration, and Plaid availability, Clarity may receive institution metadata, account names or labels, account types and subtypes, provider account identifiers, balances where supported, transaction dates, descriptions, merchants, categories, amounts, pending or posted status, account connection status, and troubleshooting metadata.

Clarity uses Plaid-connected data to provide budgeting, spending insights, transaction review, categorization, dashboard summaries, goals, and Rex assistant context. Clarity may also use this data for support, troubleshooting, reliability, abuse prevention, security, and compliance review.

Plaid-connected data is treated as Restricted Information. It should be stored only where needed to provide or support the product, scoped to the authorized user, protected from unnecessary exposure, and not sold as personal financial data or used for unrelated third-party advertising.

AI Assistant Data Handling

Rex may use approved Clarity context to help users understand spending, budgets, goals, and related product information. To generate responses, Clarity may send relevant user messages, conversation content, financial context, memory/context, and request metadata to AI model providers such as Grok.

Clarity should include only the context reasonably needed for the requested assistant feature. Rex does not independently access financial institutions, move money, open accounts, apply for credit, file taxes, make purchases, or execute financial actions.

AI prompts, responses, transcripts, and memory are Confidential or Restricted depending on whether they include sensitive financial or account information.

Retention and Deletion

Clarity retains information only as long as reasonably needed to provide the product, support users, maintain security and reliability, comply with legal or platform obligations, resolve disputes, debug issues, or preserve operational records.

Disconnecting a financial account may stop future access where supported, but historical data already stored in Clarity may remain unless deleted through product controls or a data deletion request. Some records may remain for a limited period in backups, logs, support records, security records, or systems where retention is needed for legal, fraud-prevention, dispute-resolution, security, or operational reasons.

Clarity will maintain a published contact or data deletion path for users who request account or data deletion assistance.

4. Access Control and Authentication

User Authentication

Users access Clarity through authenticated accounts using Supabase Auth and supported authentication flows. Private app data should be available only after successful authentication.

Users are responsible for keeping their devices, email accounts, and login credentials secure. Clarity support channels must not request bank passwords, full account numbers, full card numbers, Social Security numbers, one-time login codes, API keys, or private secrets.

User-Scoped Access

Clarity is designed so user records are scoped to the authenticated user who owns or is authorized to use them. This includes account records, transactions, budgets, goals, Rex conversations, memory/context, preferences, and related data.

Supabase Row Level Security should be enabled for tables containing user-scoped data. Database policies should restrict users to their own records. Backend services that require elevated privileges must be limited to defined server-side use cases and should not expose privileged credentials to the mobile client.

Founder and Administrative Access

Because Clarity is currently a solo-founder product, Pedro Martins may hold administrative access to production systems, vendor dashboards, code repositories, deployment tools, and support channels. This access is permitted only for legitimate purposes, including operations, debugging, support, privacy requests, security investigations, Plaid review, compliance, and data deletion.

Administrative access must not be used for casual browsing of user data. As Clarity grows, role separation, access reviews, and least-privilege permissions will be expanded before additional personnel receive production access.

Credential and Secret Management

Production credentials, API keys, Plaid tokens, service-role keys, and deployment secrets are Restricted Information. Clarity will avoid hardcoding secrets into source code, avoid committing secrets to repositories, store secrets in deployment secrets or provider-supported secret stores, use separate development and production credentials where supported, rotate credentials if exposure is suspected, and keep Plaid access tokens and backend service credentials server-side.

Where available, founder administrative accounts should use strong passwords and multi-factor authentication, especially for Plaid, Supabase, source code hosting, deployment, email, app store, and domain/DNS accounts.

5. Data Encryption

Data in Transit

Clarity uses HTTPS/TLS for data transmitted between the mobile app, public website, backend services, Supabase, Plaid, AI providers, and other service providers where data is sent over the internet. Production endpoints should use valid certificates and should not rely on self-signed certificates.

Sensitive information should not be sent through insecure channels or public contact forms. Clarity's public support paths should instruct users not to send bank credentials, full account numbers, full card numbers, Social Security numbers, one-time codes, API keys, or private secrets.

Data at Rest

Clarity uses managed infrastructure providers, including Supabase, to store application data. Clarity relies on provider-supported storage protections, including encryption at rest offered by those providers and the security configuration applied to Clarity's production environment.

Stored product data may include user profiles, Plaid-connected account context, transaction data, budgets, goals, Rex conversations, memory/context, support records, logs, and operational records.

Clarity does not claim end-to-end encryption, zero-knowledge storage, field-level encryption, or a specific encryption algorithm unless those controls are implemented, verified, and documented. Additional field-level protections may be evaluated as the product matures and the sensitivity or volume of stored data increases.

Logs and Backups

Logs, backups, error reports, and operational records may be maintained by Clarity or its service providers to operate, secure, debug, and improve the service. These records should be limited to operational need and protected according to sensitivity.

Logs should avoid storing Plaid access tokens, API keys, bank credentials, full account numbers, full card numbers, Social Security numbers, or other secrets. If sensitive data is accidentally logged or exposed, Clarity will treat it as a security issue, restrict or remove the data where feasible, and rotate affected credentials when appropriate.

6. Third-Party Management

Clarity uses third-party providers to operate the product. As a solo-founder company, vendor management is lightweight but intentional. Providers are selected based on product need, security posture, reliability, and fit for the data they process.

Current or expected provider categories include Plaid for user-authorized financial account connections, Supabase for authentication and managed backend infrastructure, Grok or other AI model providers for Rex assistant responses, speech-to-text or text-to-speech providers if voice features are enabled, and hosting, domain, email, monitoring, analytics, support/contact, deployment, app store, and device platform providers as needed.

Before adding a provider that processes Confidential or Restricted Information, Clarity should review what data the provider will process, why the provider is needed, whether the provider is appropriate for the sensitivity of the data, available security and privacy documentation, authentication and transport security, retention and deletion practices, AI training-use practices where relevant, and whether public disclosures need to be updated.

Clarity should share only the data reasonably needed for the provider's function. Provider names, roles, and public disclosures should be kept accurate as the product evolves.

Clarity uses Plaid for account connection and financial data access but does not represent that Plaid sponsors, endorses, certifies, or approves Clarity unless formally authorized. Clarity will follow applicable Plaid requirements for production access, user consent, data use, and security.

7. Incident Response Plan

Clarity maintains a founder-led incident response process appropriate for an early-stage product. A security incident is any actual or suspected event that could compromise Clarity systems, credentials, user data, Plaid-connected data, or service availability.

Examples include unauthorized access to user or financial data, exposure of Plaid tokens or production credentials, misconfigured database policies or backend routes exposing user data, suspicious administrative access, account compromise, vulnerability exploitation, loss or compromise of a founder device or account with production access, or provider breach notifications affecting Clarity data.

Pedro Martins is currently responsible for incident triage, containment, remediation, communication, and post-incident review. If additional personnel are added, roles and escalation paths will be documented.

Clarity's incident response process is:

1. Identify and triage: determine what happened, when it occurred, what systems or data may be affected, and whether Plaid-connected data, production credentials, or user data are involved.
2. Contain: stop further exposure or damage by disabling keys, revoking sessions, restricting access, pausing a feature, rolling back a deployment, or contacting a provider.
3. Preserve evidence: retain relevant logs, timestamps, provider notices, deployment history, screenshots, and support messages in a secure location.
4. Remediate: fix the root cause, such as patching code, correcting RLS policies, rotating credentials, updating configuration, or deploying a corrected release.
5. Recover and monitor: restore normal operation after verifying the fix and monitor for recurrence.
6. Notify as appropriate: determine whether users, Plaid, vendors, platforms, legal counsel, or regulators should be notified. If Plaid-connected data or Plaid credentials are involved, Clarity will contact Plaid through the appropriate support or account channel as required.
7. Review and improve: document the incident, impact, response, root cause, and follow-up actions, then update controls, code, documentation, or this policy where needed.

Clarity will maintain a published contact path for security concerns and vulnerability reports. Reporters should include a description, affected feature, safe reproduction steps if available, and non-sensitive contact information. Clarity does not currently operate a

formal bug bounty program and does not promise rewards or specific response-time guarantees.

8. Vulnerability Management and Patching

Clarity reviews and updates dependencies on a regular basis, including Flutter packages, Supabase libraries, backend dependencies, Plaid SDKs or API clients, AI provider SDKs, and deployment tooling.

Security updates are prioritized based on severity, exploitability, production exposure, and whether the affected component handles user data, Plaid data, authentication, or credentials. Critical production issues should be investigated immediately and remediated as soon as reasonably feasible.

Security-sensitive changes receive careful founder review before release, especially changes involving authentication, sessions, authorization, Supabase RLS policies, database permissions, Plaid token exchange or storage, account connection or webhook handling, data deletion and disconnection flows, AI context selection involving financial data, logging, analytics, monitoring, error reporting, environment variables, and secret handling.

Where practical, Clarity uses automated tests, manual QA, dependency scanning, static analysis, provider dashboard review, and production configuration checks. As the product grows, Clarity will expand automated security checks and formal vulnerability tracking.

9. Employee and Contractor Security

Clarity is currently operated by Pedro Martins as a solo founder. There are no employees or regular contractors with standing production access as of this policy.

The founder is responsible for protecting accounts and devices used for development and administration, using strong passwords and multi-factor authentication where available, keeping local development tools and dependencies reasonably updated, avoiding plaintext storage of production secrets, separating development, test, and production data where practical, handling user data only for legitimate purposes, and monitoring support, privacy, deletion, and security contact paths.

If Clarity adds employees, contractors, advisors, or vendors with access to systems or user data, Clarity will establish appropriate access controls before granting access, including least-privilege permissions, confidentiality obligations where appropriate, security onboarding, access removal when no longer needed, and periodic access review.

Contractors should not receive production data or production access unless necessary and approved by the founder. Synthetic or test data should be used when practical.

10. Policy Review and Maintenance

This policy will be reviewed at least annually and whenever material changes occur, including Plaid Production access approval or major Plaid integration changes, new categories of financial data collection or processing, new providers that process Confidential or Restricted Information, significant changes to authentication, database access, backend architecture, RLS policies, AI context handling, a security incident or near miss, addition of personnel with administrative access, or new legal, platform, or vendor requirements.

Pedro Martins is responsible for maintaining this policy and ensuring it remains accurate. Public privacy, security, terms, and data deletion pages should be updated when policy changes affect users or provider disclosures.

Planned maturity improvements may include more formal access reviews, vendor inventory, security logging and alerting, dependency and secret scanning, backup and recovery documentation, retention schedules, external security review, and a recognized security framework evaluation when commercially appropriate.

11. Approval

This Information Security Policy is approved by the founder of Clarity and is effective as of the date listed above.

Founder: Pedro Martins Title: Founder, Clarity Signature: _____ Date: _____
